

Controls & Compliance Checklist

Organization: Meridian Health Group | Audit Type: Internal IT Security Audit | Date: June 2026
Auditor: Maximilian Rivera | Risk Score: 8 / 10 (High)

SECTION 1 — CONTROLS ASSESSMENT

Does Meridian Health Group currently have this control in place?

Control / Best Practice	Yes	No
Least Privilege		X
Disaster Recovery Plans		X
Password Policies		X
Separation of Duties		X
Firewall	✓	
Intrusion Detection System (IDS)		X
Backups		X
Antivirus Software	✓	
Manual Monitoring & Maintenance of Legacy Systems		X
Encryption		X
Password Management System		X
Physical Locks (Offices, Clinics, Warehouse)	✓	
Closed-Circuit Television (CCTV) Surveillance	✓	
Fire Detection & Prevention Systems	✓	

SECTION 2 — COMPLIANCE CHECKLIST

Does Meridian Health Group currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Control / Best Practice	Yes	No
Only authorized users have access to customers' credit card information		X
Credit card data is stored, accepted, processed, and transmitted securely		X

Control / Best Practice	Yes	No
Data encryption procedures are in place for credit card transactions		X
Secure password management policies have been adopted		X

General Data Protection Regulation (GDPR)

Control / Best Practice	Yes	No
E.U. patients' data is kept private and secured		X
A plan exists to notify E.U. patients within 72 hours of a breach	✓	
Data is properly classified and inventoried		X
Privacy policies, procedures, and processes are enforced	✓	

System and Organizations Controls (SOC Type 1 & Type 2)

Control / Best Practice	Yes	No
User access policies are established		X
Sensitive data (PII/SPII) is treated as confidential and private		X
Data integrity ensures information is consistent, complete, and validated	✓	
Data is available to individuals authorized to access it	✓	

SECTION 3 — RECOMMENDATIONS

The following controls and compliance measures represent the highest-priority gaps. Addressing these will have the greatest impact on reducing organizational risk and achieving regulatory compliance.

- Implement encryption immediately for all payment card and patient health data in storage and transit to satisfy PCI DSS and HIPAA requirements.
- Establish a least privilege access control policy and deploy a password management system to reduce the risk of unauthorized access across all internal systems.
- Develop and test a formal disaster recovery plan to ensure business continuity in the event of a security incident or system failure.
- Deploy an Intrusion Detection System (IDS) to enable real-time visibility into network threats and anomalous activity.
- Implement a data classification and inventory process to support GDPR compliance and prepare for E.U. regulatory scrutiny as the organization grows internationally.
- Establish a separation of duties policy to reduce insider threat exposure and ensure no single employee has unchecked access to critical systems or patient data.

This checklist was completed as part of a structured internal security audit using the NIST Cybersecurity Framework (CSF). All findings are based on the current state of Meridian Health Group's security posture as documented in the scope, goals, and risk assessment report.